

Original Article

SECURITY THREATS TO AI AGENTS: REVIEW ON THREATS, DEFENSE STRATEGIES AND THREAT MODELLING

Geethu Merin Mathew ^{1*}, Kapil Shukla ², Krishna Modi ³

¹ National Forensic Sciences University, India

² National Forensic Sciences University, India

³ National Forensic Sciences University, India



ABSTRACT

Artificial intelligence agents are no longer simply language-based systems; rather, they are becoming autonomous entities that can reason, use tools, interact with external environments, and collaborate with each other. This has led to a significant increase in the scope of security threats associated with artificial intelligence agents, shifting the focus from machine learning-based security threats to more complex system-level security threats. This review aims to highlight the emerging security threats associated with artificial intelligence agents by bringing together various recent research works related to artificial intelligence agents, language model security, and autonomous decision-making systems. This study highlights the various significant types of security threats associated with artificial intelligence agents and analyze these types of threats in detail. These types of security threats include input-level attacks, model-level attacks, tool-level attacks, memory and state manipulation attacks, environment-level attacks, and multi-agent level attacks. The review aims to highlight various types of defense mechanisms available against these types of security threats, including input sanitizing, tool filtering, isolation architectures, safety agents, and policy-based tool execution. The review aims to highlight various recent advancements in threat modeling techniques like ASTRIDE, ATFAA, MAESTRO, and risk scoring techniques related to critical security threats like prompt injection attacks, memory poisoning attacks, unauthorized tool usage, and data exfiltration. The analysis has shown that currently available defense mechanisms against various types of security threats associated with artificial intelligence agents are limited and insufficient in nature; therefore, a systems security approach is required to address artificial intelligence agent security issues by considering architectural safeguards, standard evaluation benchmarks, better management of memories and tool usage in artificial intelligence agents, and better alignment of security requirements with governance requirements.

Keywords: AI Agents, Agentic AI Security, Prompt Injection, Memory Poisoning, Tool Misuse, Threat Modelling, Autonomous Systems, Large Language Models

INTRODUCTION

Artificial intelligence (AI) has moved from traditional machine learning systems to large language models, and more recently to autonomous AI agents that can reason, plan, use tools, access memory, and interact with external environments, these advances also create significant security issues. Unlike traditional AI systems, where errors in output or text generation are a concern, AI agents can perform actual actions, access sensitive information, and impact real-world processes. Therefore, whereas traditional AI systems

***Corresponding Author:**

Email address: Geethu Merin Mathew (geethumerinm@gmail.com), Kapil Shukla (kapil.shukla@nfsu.ac.in), Krishna Modi (krishna.modi@nfsu.ac.in)

Received: 06 April 2026; **Accepted:** 23 May 2026; **Published** 06 June 2026

DOI: [10.29121/DigiSecForensics.v3.i1.2026.98](https://doi.org/10.29121/DigiSecForensics.v3.i1.2026.98)

Page Number: 56-66

Journal Title: Journal of Digital Security and Forensics

Journal Abbreviation: J. Digi. Sec. Forensics

Online ISSN: 3048-894X

Publisher: Granthaalayah Publications and Printers, India

Conflict of Interests: The authors declare that they have no competing interests.

Funding: This research received no specific grant from any funding agency in the public, commercial, or not-for-profit sectors.

Authors' Contributions: Each author made an equal contribution to the conception and design of the study. All authors have reviewed and approved the final version of the manuscript for publication.

Transparency: The authors affirm that this manuscript presents an honest, accurate, and transparent account of the study. All essential aspects have been included, and any deviations from the original study plan have been clearly explained. The writing process strictly adhered to established ethical standards.

Copyright: © 2026 The Author(s). This work is licensed under a [Creative Commons Attribution 4.0 International License](https://creativecommons.org/licenses/by/4.0/).

With the license CC-BY, authors retain the copyright, allowing anyone to download, reuse, re-print, modify, distribute, and/or copy their contribution. The work must be properly attributed to its author.

were vulnerable to errors, AI agents can also be vulnerable to prompt injection, tool misuse, memory poisoning, environment manipulation, and compromising multiple agents. This evolution, therefore, indicates that AI agent security is not just a model-level problem, but a systems-level problem.

In the earlier days, the security research on the subject concentrated on the vulnerabilities related to the entire lifecycle of data collection, training, inference, and deployment. But with the advent of large language models, prompt injection, jailbreaking, and the leakage of hidden instructions, the security landscape completely transformed because the interface, which is the input, also came into the picture. But with the advent of AI agents, the security landscape is even larger. As evident from the recent research discussed in your review, the security threats to the current agential AI systems extend beyond the threat of prompt-based attacks to the entire spectrum of tool-based attacks, API attacks, memory attacks, environment attacks, multimodal attacks, and even attacks involving the compromise of multiple agents. This is because the question being asked on the security front is no longer related to the safety of the model to the extent that it can be manipulated to produce unsafe text.

At the same time, the literature indicates that defending an AI agent is significantly harder than defending a traditional model. The existing defenses such as prompt filtering, structured prompts, shield prompts, safety agents, and isolation-based architectures have shown promise but are incomplete and very specific to a number of attacks. Additionally, traditional approaches such as STRIDE do not adequately address the complexities of autonomous agents. Therefore, new approaches such as ASTRIDE, ATFAA, and MAESTRO have been developed to address the complexities of autonomous agents and the different potential sources of threats. The approaches acknowledge that threats may come not only from inputs and outputs but also from reasoning, memory, planning, tool invocation, infrastructure, and coordination. Hence, the security of an AI agent is a systems problem that requires a comprehensive solution. Therefore, this paper critically examines the evolving security threats for AI agents, the existing defense strategies and approaches for threat modeling, and identifies the gaps that need to be addressed for the development of secure and robust agentic systems.

LITERATURE REVIEW

The security literature first views AI as being vulnerable throughout the end-to-end lifecycle of data, training, inference, and deployment, which means that there is a need for systematic threat modeling and defenses rather than viewing failures as anomalies. [Oseni et al. \(2020\)](#) highlight security as a key property, related to attacker goals and capabilities, and note that there is a need for structured mitigation strategies for AI deployments, not simply performance improvements.

In the case of large language models, the interface is the attack vector. [Perez and Ribeiro \(2022\)](#) demonstrated this with prompt injection attacks to subvert the objective function and leak hidden instructions, arguing that it is hard to defend against this if the defense is based solely on the prompt and the distinction between trusted and untrusted inputs. As AI systems grow in scope into real-world domains, security failures become societal harms. [Huang et al. \(2023\)](#) integrate ethical risks (privacy, discrimination, accountability) and link technical vulnerabilities to broader governance requirements, thus reinforcing “secure AI” as “trustworthy AI.”

The year 2024 promises a shift from solely LLM-based threats to agent-based threats, which include tools, memory, and autonomy. [Rossi et al. \(2024\)](#) provide a formalization of early prompt injection categorization, with a focus on the ongoing “cat-and-mouse” game, which they say makes prompt-only defenses fragile. Empirical validation provided by [Yu et al. \(2024\)](#) with a real-world experiment using 200+ custom GPTs, showing high success in system prompt extraction and leakage, demonstrating the power of customization coupled with tool/file access. Moreover, [Zhang et al. \(2024\)](#) demonstrate how attackers can leverage autonomous agents through malfunction amplification, which shifts the threat from unsafe outputs to unsafe behaviors. [Chen et al. \(2024\)](#) address the requirement for visibility in governance, which makes agent usage auditable and accountable. Practical safety architecture was proposed by [Domkundwar et al. \(2024\)](#), which includes filters, safety agent components, and a hierarchical delegation framework, to minimize unsafe behaviors in agent-based systems.

By 2025, the consensus among the literature is clear agent security is systems security, including tools, memory, execution environments, other agents, and humans. Browsing agents serve as an example to illustrate the perils of untrusted environments. [Mudryi et al. \(2025\)](#) describe the exploitation paths involving agent injection, including credential exfiltration and bypass, in the context of browsing agent environments. Expanding this to the context of GUI/desktop/mobile agent automation, [Chen et al. \(2025a\)](#) offer a significant survey on the security of Computer Using Agents (CUAs), including definitions and classification of threats into intrinsic and extrinsic categories, including UI grounding errors, scheduling errors, prompt injection, jailbreaks, memory injection, and backdoors. They also offer a mapping to defensive strategies and benchmarks. Their main contribution is demonstrating the security issues introduced by the combination of multimodal perception and action execution.

In terms of defending against the injection and tool-misuse threats, the consensus among the literature is moving towards the application of architectural controls. [Beurer-Kellner et al. \(2025\)](#) propose system design patterns for enforcing boundaries, including plan and execute separation, context minimization, and isolation, which reframes the defense against agent injection attacks as a design issue, not one involving prompt design. They also describe the application of guardrail techniques. [Chennabasappa et al.](#)

(2025) introduce the concept of LlamaFirewall as a guardrail-based security approach to defending agent workflows against jailbreaks, alignment attacks, and code safety.

As defenses are developed, evaluation is also needed. A large-scale public competition study by Zou et al. (2025) showed the effectiveness of prompt injection for agents and emphasized the distinction between robustness and model size. Moreover, Multi-agent benchmarking systems seem to also assess overall compromise and not individual failures Sharma et al. (2025), such as cascading injection and propagation metrics.

EXISTING DEFENCE MECHANISM

A look at the existing defence mechanisms reveals that current research has moved from individual prompt-level fixes to a suite of multi-layered protections for AI agents, which include input filtering and sanitization, prompt structuring, output validation, tool filtering, system isolation, policy-based execution control, active monitoring, safety agent review, and human supervision. From a look at the existing studies in your draft, these mechanisms are intended to reduce the effects of prompt injection, jailbreaks, tool-based attacks, data flow hijacking, data exfiltration, and deceptive alignment, amongst other attacks, through a separation of trusted prompts from untrusted input, control of tool usage, validation of unsafe outputs before execution, and monitoring of agent behaviour during runtime. From a look at the empirical results provided in the table, there are indications that some of these mechanisms are capable of significantly reducing attack success rates, with some having little or no effect on utility, but a look at existing studies indicates that these mechanisms are still incomplete, fragmented, and attack-specific, with common issues in existing studies including brittleness in the face of adaptive attacks, high false positives, token overhead, loss of flexibility, and failure to provide a comprehensive and standardized security architecture for autonomous agentic artificial intelligence systems.

Table 1

Table 1 Analysis of Existing Defence Mechanisms						
S.no	Author	Year	Attack Type	Defense Proposed	Evaluation	Limitation
1	Chen et al. (2024)	2024	Prompt injection, completion attacks, escape attacks, HackAPrompt, TAP, GCG	StruQ: structured queries with reserved delimiters, front-end token filtering, and structured instruction tuning so the model follows only prompt-channel instructions and ignores data-channel instructions	Reduced tested manual attack success rates to <2%; reduced TAP from 97% to 9% and GCG from 97% to 58% on Llama; little or no utility loss	Not fully secure against strong optimization-based attacks, limited to programmatic LLM-integrated applications, and not designed for multi-turn chatbots or broader agent defenses
2	Debenedetti et al. (2024)	2024	Indirect prompt injection, malicious tool-output hijacking	Data delimiting, prompt injection detection, prompt sandwiching, and tool filtering for restricted tool access	On AgentDojo's 629 security test cases, tool filter achieved the best result with 6.84% targeted ASR; prompt injection detector achieved 7.95% ASR but severely reduced utility due to false positives	Defenses remain brittle: detector has high false positives, sandwiching is weak to adaptive attacks, and tool filtering fails when tools cannot be pre-planned or overlap with attacker goals
3	Chennabasappa et al. (2025)	2025	Prompt injection, jailbreaks, goal hijacking, insecure code generation	PromptGuard 2 for input filtering/prompt sanitization; AlignmentCheck for reasoning-based misalignment detection; CodeShield for output validation; layered pre-execution checks over untrusted retrieved/tool content	PromptGuard recall 97.5% @ 1% FPR; combined defenses reduced AgentDojo ASR from 17.6% to 1.75%; CodeShield achieved 96% precision and 79% recall	Limited coverage for subtle/contextual attacks, AlignmentCheck has latency/compute cost and remains experimental, CodeShield is not comprehensive

4	Barua et al. (2025)	2025	Many-shot jailbreaking, prompt injection, deceptive alignment	Multi-agent defense with active monitoring; GrootAI performs harmful-content detection, response blocking, and safe-response generation; sandbox/tool-mediated execution and observer-based deception detection are also emphasized	Reverse Turing Test accuracy up to 94%; ObserverAI TPR 98% in no-faking setting; defense can detect/block some harmful multi-turn outputs	Persistent long-context attacks still succeed; simulations are not fully real-world; prior static defenses remain insufficient; no explicit memory segmentation or retrieval verification
5	Beurer-Kellner et al. (2025)	2025	Prompt injection, indirect prompt injection, unauthorized tool use, data exfiltration	Prompt injection, indirect prompt injection, unauthorized tool use, data exfiltration	Evaluated through ten case studies; shows that system-level isolation can give meaningful prompt-injection resistance across diverse agent applications	Mostly conceptual rather than empirical; reduces agent flexibility and utility; many defenses still rely on task decomposition and cannot fully stop all parameter/content manipulation
6	Domkundwar et al. (2024)	2025	Jailbreaking, unsafe prompts, harmful output generation	Three safety architectures: LLM-based input-output filtering, dedicated safety agent for output review/editing, and hierarchical delegation-based safety checks between agent actions	Evaluated on 21 malicious prompts; GPT-4o improved from 1.87 (no safety) to 2.94 (LLM filter), 2.81 (safety agent), and 3.0 (hierarchical); image-safety agent scored 3.00 vs 2.20 baseline	Vulnerable to fictional/urgency-based bypasses, hierarchical process adds 2–3 minutes and higher cost, dataset is small, and only one agent setting was tested
7	Debenedetti et al. (2024)	2025	Prompt injection, indirect prompt injection, data-flow hijacking, data exfiltration	CaMeL: dual-LLM isolation (Privileged + Quarantined LLM), capability-based security policies, provenance/data-flow tracking, policy-checked tool execution, and explicit approval for unsafe actions	On AgentDojo, CaMeL greatly reduced attack success and in baseline comparison achieved 0 successful attacks; it outperformed prompt sandwiching, spotlighting, and tool filtering, though with some utility and token overhead	Does not cover all non-control/data-flow attacks, may require human approval and policy maintenance, vulnerable to side channels, and introduces deployment and token overhead
8	Wang et al. (2025b)	2025b	Prompt injection, adaptive jailbreaks, context manipulation, obfuscation, payload splitting	Polymorphic Prompt Assembling (PPA): randomized separator pairs and prompt templates to isolate user input from system instructions; prevention-based prompt-structure randomization instead of filtering or fine-tuning	Evaluated on 1,200 attack samples across 12 attack types; ASR reduced to 1.83% (GPT-3.5), 1.92% (GPT-4), 4.28% (DeepSeek-V3), and 8.17% (LLaMA-3); 97.68% on Pint-Benchmark and 99.40% on GenTel-Bench with 0.06 ms overhead	Evaluated mainly on summarization; weaker on some models and contextual attacks; does not address tool isolation, retrieval verification, memory segmentation, or human-in-the-loop validation
9	Chen et al. (2025b)	2025b	Direct and indirect prompt injection, ignore, escape, fake completion, combined attacks, GCG, AutoDAN	Attack-inspired shield prompting: Ignore Defense, Escape Defense, Fake Completion Defense, and Fake Completion Defense with Template; these append defensive prompts that restate or	Strongest method (Fakecom-t) reduced ASR close to zero on many indirect attacks, strongly outperformed training-free baselines, and reduced GCG/AutoDAN ASR to 9.61% and 10.57%	Prompt-engineering only, no formal guarantees, no tool isolation or memory segmentation, and limited evidence for long-query robustness

re-confirm the original trusted instruction						
10	Su et al. (2025)	2025	Prompt injection, memory poisoning, tool misuse, reward hacking, emergent misalignment, multi-agent attacks	Layered defenses across input sanitization, memory lifecycle control, risk-aware planning, execution guarding, and feedback/self-governance; proposes R2A2 with constraint filtering, reflective reasoning, risk-aware world modeling, and human supervision	Conceptual survey-based evaluation; synthesizes prior defenses across autonomy layers and proposes R2A2 as an integrated CMDP-based safety architecture	Largely conceptual rather than experimentally validated; current defenses remain fragmented, with unresolved gaps in memory control, secure tool enforcement, adversarial feedback handling, and end-to-end guarantees

METHODOLOGY

In the context of the present research, the qualitative review-based approach is followed in order to explore the concept, threat categorization, and defense strategies of AI agentic Security. In order to collect the relevant literature, various secondary sources such as academic journals, government publications, legal documents, institutional publications, and authentic online databases are used.

Precedence has been given to the recent research and articles published between 2022 and 2026, keeping in view the inclusion of updated information on emerging Agentic security threats. The collected literature has been reviewed and analyzed in order to identify the patterns, mechanism, implications, and challenges associated with Security threats to AI agents. A comparative and analytical approach has been followed in order to synthesize the information and identify the gaps in the existing research.

TAXONOMY OF SECURITY THREATS TO AI AGENTS

The Literature has also focused on categorizing and discussing the Security threats to AI agents. In this section, we divided the threats into Input-level attacks, Model-level attacks, Tool-level attacks, Memory and State Manipulation, Environment-level attacks, Multi-agent attacks.

Figure 1

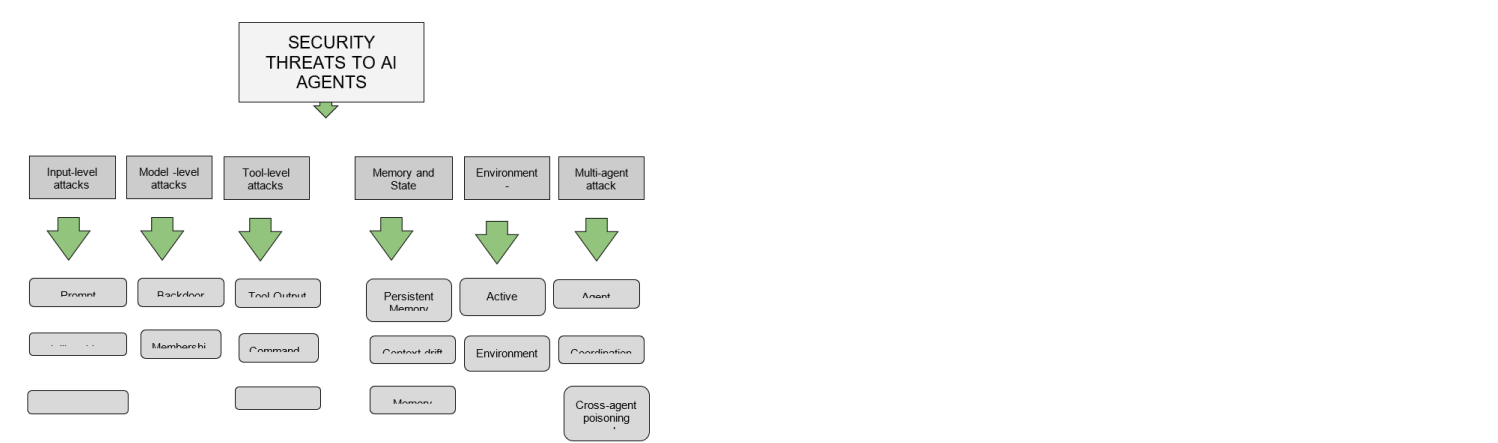


Figure 1 Taxonomy of Security threats to AI Agents

INPUT - LEVEL ATTACK

This category includes techniques that disable LLM functionality through input manipulation, such as text, code, or multimodal input before model processing. This includes direct and multi-step prompt injection techniques, such as SQL-based attacks in LangChain; dynamic and covert prompt overrides; extended context jailbreaks; and fuzzing-based automated jailbreak generation. Prompt Injection is the most common and dangerous threat to AI agents. In their research related to prompt injection, [Perez and Ribeiro \(2022\)](#) investigate the security vulnerabilities associated with transformer-based large language models, such as GPT-3, which arise because of adversarial inputs by the users. [Pedro et al. \(2023\)](#) discuss security issues in web applications that utilize

Large Language Models (LLMs). The main focus of the paper was to discuss the security issues caused by SQL injection, which occurred via unsanitized user input. The input will be used to generate SQL queries in systems that combine LLMs and middleware technologies like LangChain. If not sanitized, the input can allow an attacker to inject malicious SQL queries, hence compromising the database. Another type of Input level attack is Jailbreak attacks, Both [Kumar et al. \(2025\)](#) and [Chiang et al. \(2025\)](#) clearly illustrate that AI agents are far more susceptible to jailbreak attacks than the underlying LLMs. In the agentic framework, these weaknesses are particularly high-stakes because a single successful jailbreak could lead to a chain of harmful actions due to the autonomous nature and access to external tools such as search engines and code interpreters. Moving on from runtime manipulations to basic threats, focuses on threats such as data poisoning . Data poisoning is a traditional adversarial threat to machine learning models, which tries to reduce their performance by manipulating their training data. In this type of attack, adversaries cleverly inject malicious or fake data in the training data, which causes a machine learning model to learn incorrect patterns during training, hence making incorrect predictions during runtime [Xiang et al., \(2025\)](#)

MODEL-LEVEL ATTACKS

This section focuses on persistent threats, extending beyond a single query, such as backdoor, where malicious behavior is embedded within LLMs' basic operations. Recent studies on parameter-level backdoors, such as BadAgent and DemonAgent, and prompt-level backdoors, such as BadPrompt and PoisonPrompt, demonstrate how "hidden" backdoors remain dormant until specific conditions activate them. In an attempt to achieve maximum stealth and sophistication, more recent and complex backdoor attacks, such as composite backdoor attacks, utilize multiple triggers within multiple parts of a prompt. Backdoor attacks are also discussed by [Yang et al. \(2024\)](#) as a significant safety concern for LLM-based agents that are increasingly being deployed in practical scenarios such as e-commerce, health care, and finance. The authors argue that, compared to traditional backdoor attacks on LLMs, which are limited to user inputs and final outputs of the LLMs, backdoor attacks on LLM-based agents are stealthier and more versatile. The authors argue that these attacks may interfere with the agent's internal reasoning process while yielding apparently correct final responses. In their investigation on security flaws in prompt-based learning for large language models, author focuses on the risk of backdoor attacks. The author argues that despite the wide use of prompt-based learning in various applications of LLMs and its associated improvements in job performance, its backdoor risks have not been thoroughly investigated. They recommend an attack called PoisonPrompt, which is a backdoor attack aimed at compromising both hard prompt-based and soft prompt-based LLMs. The attack is not only possible but also difficult to trace based on the authors' assessment of different prompt learning methods and datasets. The research by the author thus points to the need for strengthening defenses in prompt learning pipelines.

The literature also focused on attacks like Membership Inference, demonstrates that there is a unique privacy risk in RAG(retrieval augmented generation) models, which can be leveraged by the black-box S2MIA attack proposed in their work, which can even determine whether a particular sample exists in the external knowledge database based on perplexity and semantic similarity signals (Li et al.). It shows that sensitive membership information may leak from the retrieval level even without internal model access.

TOOL-LEVEL ATTACKS

Tool level attacks pose a serious security threat to LLM based agents because the reliance on external APIs, web content, databases, files, and memory systems exposes the Agent to security threats. [Su et al. \(2025\)](#) point out tool misuse and memory poisoning as security threats to autonomous AGs. Furthermore, [Li et al. \(2025\)](#) show the security threats to Agents arising from malicious APIs, search results, and knowledge sources. They show how these security threats can trick the agent into divulging confidential information, downloading malware, and violating safety constraints. Moreover, [Nakash et al. \(2024\)](#) show how tool level attacks can manipulate the tool output to embed hidden instructions that can trick the AG into violating its reasoning. [Yang et al. \(2024\)](#) show how backdoor triggers embedded in environmental observations can trick the AG into behavior. At the execution level, [Zhang et al. \(2025\)](#) and [Triedman et al. \(2025\)](#) show the security threats to Agents arising from Text-to-SQL tools and code execution tools. They demonstrated the attack with a malicious Delete SQL delete query ;DELETE FROM artists WHERE ID < 5000,thereby erasing the records in the database.

MEMORY AND STATE MANIPULATION

The literature also focused on Memory and state manipulations have highlighted as important threats to LLM-based agents because the retention of internal states enables the adversarial influence to extend beyond the original conversation. [Su et al. \(2025\)](#) propose the notion of persistent memory poisoning, which, according to them, is an essential security risk in autonomous agents, wherein adversarial inputs in the agents' evolving internal memory can be recalled in the future as trusted context and can lead to the delayed and cumulative compromise of agents' future reasoning in interactions, a notion that is further highlighted by Chen et al.'s AgentPoison, Dong et al.'s memory injection attacks, and Ferrag et al.'s classification of MINJA as a memory poisoning model compromise attack. The author extend the discussion to Context drift. It is defined as a type of gradual memory state attack where "stale, poisoned, or self-reinforced summaries, reasoning traces, and past interactions are continuously treated as valid context for

the purpose of grounding, even as the objectives or environments evolve, enabling the normalization of tainted context within the continuous reasoning process of the agent, as further evidenced by the work (Hatalis et al. and [Ferrag et al., \(2025\)](#) resulting in the continuous behavioral inconsistency, unauthorized actions, or violation of protocols by planning-based agents. Another System level vulnerability was discussed by author, Memory corruption in which persistent state faults propagate through perception, planning, recall, tool usage, self-reflection, and multi-agent communication, such that persistent memory poisoning and context shifts culminate in a system-level breakdown in cognitive integrity as also discussed in relation to reflective memory management (Tan et al.), memory thus becomes an active part of an agent's cognition that must be managed, bounded, and controlled through mechanisms such as provenance-aware storage, validation, and self-modification.

ENVIRONMENT-LEVEL ATTACKS

The literature also discussed the Environment level attacks like Active Environment Injection, injection on GUI/ web etc. Active Environment Injection Attacks (AEIA) is considered as a novel threat to multimodal mobile agents. The author demonstrated how attackers could use malicious commands in the form of legitimate OS interface components such as notifications and pop-ups to leverage the vulnerability of content injection and reasoning gaps for malicious purposes [Chen et al., \(2025\)](#). Environment injection is also became a one of the major attacks on the security of GUI and web agents, as the decision-making process is based on the interface content. Environment injection attacks can be used to embed malicious instructions into the webpage, pop-ups, and interface to manipulate the agent. The effect of peripheral disturbances on the perception and reasoning of the agent was shown by [Ma et al. \(2024\)](#). It is evident from these studies that the interface is one of the attack carriers for the security of GUI and web agents.

MULTI-AGENT ATTACKS

The literature also mentions distinct class of security threat by multi-agent systems because malicious behaviour spreads through inter-agent behaviour. A key risk identified is that of collusion, whereby agents utilize covert or steganographic communication channels, such as those embedded in natural language, environments, or message exchanges, to collaborate deception strategies while remaining indistinguishable from benevolent collaborators. Another significant risk identified is coordination attacks, whereby groups of agents utilize their combined skills to mount swarm or heterogeneous attacks, such as probing, bypassing single-agent defenses, and spreading attacks across multiple agents such that each appears to be acting individually and innocently. The paper also identifies cross-agent poisoning and infection attacks, whereby knowledge, misinformation, jailbreak prompts, or poisoned inputs transmitted through agent networks and shared retrieval environments enable infected behavior to propagate from one agent to multiple agents [Schroeder de Witt \(2025\)](#).

ANALYSIS AND DISCUSSION

RISK ASSESSMENT AND THREAT MODELLING

The literature also focused on Risk assessment and threat modelling methods. It offers a critical analytical framework for grasping the nature of these threats, the systems or processes they target, and the risks that need the most immediate attention. In this respect, recent research extends traditional threat modeling schemes such as STRIDE and incorporates agent specific threats. In this regard, the traditional STRIDE threat modeling approach is extended to accommodate AI/ML systems through the STRIDE-AI approach, whereby the ML-centric CIA³-R security hexagon comprising authenticity, integrity, non-repudiation, confidentiality, availability, and authorization is related to spoofing, tampering, repudiation, information disclosure, denial of service, and elevation of privilege, respectively, thus laying the groundwork for the early adoption of AI centric threat modeling approaches. Following from this, [Bandara et al. \(2025\)](#) propose that the traditional STRIDE approach is not adequate for agentic AI systems, thus necessitating the extension of the approach to the ASTRIDE approach through the addition of an AI agent-centric attack type, whereby threats such as prompt injection, context poisoning, manipulation of the reasoning process, unsafe tool invocation, misuse of memory/context windows, among others, are addressed. In the same time, [Narajala and Narayan \(2025\)](#) demonstrate that while the traditional STRIDE approach is still relevant in the context of the emerging threat landscape, the approach must be reinterpreted in the context of the emerging threat landscape with regard to the risks associated with the misuse of the reasoning process, objective manipulation, memory poisoning, unauthorized action execution, exploitation of trust relationships, oversight saturation, and evasion of governance controls, among others, thus necessitating the adoption of the newly introduced ATFAA (Advanced Threat Framework for Autonomous AI Agents) approach. ATFAA is a framework for a specialized threat modeling of generative AI agents that groups nine agent-specific threats into five domains of cognitive vulnerabilities, temporal persistence, operational execution, trust boundaries, and governance circumvention, and which is informed by the fundamental principles of cognitive security, execution integrity, identity coherence, and governance scalability. The framework illustrates the expanded and evolving threat landscape of autonomous agents due to their autonomy, memory, reasoning capabilities, and tool use.

Literature acknowledge that even though STRIDE is considered as crucial classical threat modelling baseline, it found to be inadequate for agentic AI due to its inability to accurately capture autonomous reasoning, memory, tool invocation, and emergent multi-layer behaviour. More specilized, layered framework for agentic AI called MAESTRO was introduced [Zambare et al., \(2025\)](#).

The sources of threats are not limited to inputs and outputs of these systems; they can come from perception, planning, reasoning, memory, action, knowledge, infrastructure, and coordination as well. Unlike a conventional threat model, MAESTRO divides the stack of these agents into seven different interconnected layers, enabling a threat analyst to identify not only the initial source of exploitation of a threat but also track the path of a threat in the system. Accordingly, in this framework, manipulation of instructions is related to perception and action; manipulation of goals and chain of thought is related to planning and reasoning; manipulation of memories and context is related to memory and reasoning; critical system interaction is related to action; planning and reasoning exploits are related to planning and memory; knowledge base poisoning is related to knowledge and reasoning; resource exhaustion and supply chain compromise are related to infrastructure; and multi-agent exploitation is related to memory and coordination. MAESTRO is a more accurate way of identifying and understanding threats in agentic AI systems by demonstrating how a threat can occur in one layer and then propagate across the entire stack of operations [Zambare et al., \(2025\)](#).

RISK SCORING

Risk scoring is a good approach for providing a structured method of enhancing qualitative threat analysis for agentic AI systems by prioritizing the urgency and severity of identified threats. This is important because not all threats are of equal danger level. Some are simple to exploit but have limited consequences, while others are less frequent but have the potential to threaten multiple levels of an autonomous system, including reasoning, memory, tool use, external data interaction, and user trust. A simple and effective method is to use a five-point scale for likelihood and impact for each threat and calculate the overall risk level by multiplying the two ratings together. The overall risk level = likelihood × impact. This provides a risk level ranging from low to critical. A further refinement of this method is to include a third dimension of detection difficulty for threats such as memory poisoning, goal drift, and manipulation of reasoning that may not be detected but will continue to influence decision-making over time.

Table 2

Table 2 Threat Scoring					
Threat	Likelihood(1-5)	Impact(1-5)	Risk Score	Risk Level	Justufication
Prompt Injection	5	5	25	Critical	Easy to perform and can alter reasoning, outputs, and tool use
Memory poisoning	4	5	20	Critical	Persistent attack that influences future behavior and is hard to detect
Unauthorized tool use	4	3	20	Critical	Trigger harmful actions, API misuse
Data exfiltration	4	5	20	Critical	Threatens Confidentiality
Goal hijacking	4	5	20	Critical	Redirection from intended objective and behaviour
Output Manipulation	5	4	20	Critical	Affect the integrity of generated content
Identity spoofing	3	4	12	High	Exploit trust boundaries and unauthorized access
Content flooding/ Dos	4	3	12	High	Affects availability through overload/ service disruption
Multi-agent collusion	3	5	15	High	Severe in coordinated environments

KEY CHALLENGES IN AI AGENT SECURITY

A significant problem in the security of AI agents is long-horizon autonomy, where there is a need for safe behaviors in long, multi-step tasks involving planning, memory, sequential context management, and tool usage. In these scenarios, small errors, misleading triggers, or failure in partially observable environments can build up to unsafe behaviors, which may not be evident in short-horizon tests [Datta et al., \(2025\)](#), [Deng et al., \(2025\)](#). This problem is compounded in complex systems, where there are internal complexities in agentic systems, which are typically complex and opaque, involving prompt reformulation, reasoning, planning, memory, and tool usage, which are difficult to observe in real-time. As [Deng et al. \(2025\)](#), [Narajala and Narayan \(2025\)](#), and [Datta et al. \(2025\)](#) argue, attackers may manipulate not just outputs, but also goal decomposition, action selection, memory management, and tool usage, which are interrelated in complex systems. Another problem in complex systems is the persistence of memory, which causes contamination, adversarial recall, policy drift, and hidden misalignment, while tool and API usage allow symbolic reasoning failure to directly result in unauthorized access, unsafe behaviors, and regulatory violations. Another problem in complex systems, which has received significant attention in the literature, is propagation and cascading failure, where a single faulty agent can spread harmful commands, misinformation, or adversarial influence through multiple connected systems, which causes security failure in complex systems [Datta et al., \(2025\)](#), [Deng et al., \(2025\)](#), [Zou et al., \(2025\)](#).

Another major challenge has come from open environments, in which agents have to function in dynamic, heterogeneous, and partially trusted environments involving external data, users, networks, tools, and physical environments. Deng et al. (2025) have shown how such environments can pose risks of indirect prompt injection, resource exhaustion, feedback manipulation, poor isolation, and unsafe decisions in the real world. Sengupta (2024) has highlighted other risks such as adversarial inputs, data poisoning, channel attacks, and lateral spread in the context of communicating agents. At the same time, there remain significant evaluation challenges because current research lacks sufficiently standardized, security-focused, and comparable frameworks for evaluating agentic risk. Deng et al. (2025), Ferrag et al. (2025), and Datta et al. (2025) have pointed out that current research lacks sufficient standards for evaluating agent risk. Finally, there has been a new class of challenges related to privacy and legal compliance because of the fact that autonomous agents have started to access databases, APIs, long-term memory, and inter-agent communication channels that pose risks of unintended disclosure, reconstruction, and legal non-compliance of personal and organizational data. As discussed by Khan et al. (2024), Olugbile et al. (2025), and Wang et al. (2025a), these risks are not limited to data leakage, re-identification, profiling, poor traceability, privacy reconstruction by other agents, and legal non-compliance of autonomous data flows.

RESEARCH GAP

Although recent research has pointed out some of the significant threats and different defense mechanisms, the current literature is fragmented. Most of the literature is focused on the prompt injection of threats, jailbreaks, and other such issues. However, threats such as memory attacks, compromising the toolchain, environment-level threats, and the spread of threats among different agents have not been explored in detail. Moreover, most of the defense mechanisms are specific to different threats. Another major research gap in the current literature is the lack of standardized security frameworks for the implementation of AI agents. It is very difficult for organizations to implement security for AI agents. Thus, a major research gap in the current literature is the lack of a unified security framework for the security of AI agents. The security framework should address different aspects of security such as the security of the agent itself, memory, tools, environment, and different aspects of governance.

CONCLUSION

This review also reveals that the security of AI agents has turned into a system security problem that far exceeds the security of traditional AI systems or LLMs. Since these AI agents can perform reasoning, use tools, retain memory, interact with external environments, and work in collaboration with other agents, these agents are more vulnerable to a wide variety of threats such as prompt injection attacks, tool misuse, memory poisoning, environment manipulation, and agent collaboration attacks. Even though the current defense mechanisms and threat modeling techniques have shown some progress in securing AI agents, these mechanisms are fragmented, attack-centric, and insufficient for securing these agents. Thus, future research should concentrate on developing security architecture, evaluation criteria, deployment guidelines, and more powerful governance and compliance features for securing these agents.

ACKNOWLEDGMENTS

None.

REFERENCES

- Anakha, P. P., Dilsha, M. S., Gopika, K. M., Kavya, M. M., Srithisha, R. S., and Vaishnavy, K. U. (2025). From Assistants to Adversaries: The Security Risk of Advanced AI. <https://doi.org/10.47392/IRJAEM.2025.0490>
- Arif, A., Khan, M. I., and Khan, A. R. A. (2024). An Overview of Cyber Threats Generated by AI. *International Journal of Multidisciplinary Sciences and Arts*, 3(4). <https://doi.org/10.47709/ijmdsa.v3i4.4753>
- Bandara, E., Hass, A., Gore, R., Shetty, S., Mukkamala, R., and Bouk, S. H. (2025). ASTRIDE: A sEcurity Threat Modeling Platform for Agentic-AI Applications.
- Barua, S., Rahman, M., Islam, R., Khaled, S., and Sadek, M. J. (2025). Guardians of the Agentic System: Preventing Many-Shot Jailbreaking with Agentic Systems.
- Bazińska, J., Mathys, M., Casucci, F., Rojas-Carulla, M., Davies, X., Souly, A., and Pfister, N. (2025). Breaking Agent Backbones: Evaluating the Security of Backbone LLMs in AI Agents (arXiv:2510.22620). arXiv.
- Beurer-Kellner, L., Buesser, B., Cretu, A.-M., Debenedetti, E., Dobos, D., Fabian, D., Fischer, M., Froelicher, D., Grosse, K., Naeff, D., et al. (2025). Design Patterns for Securing LLM Agents Against Prompt Injections.
- Bhuiyan, S., and Park, J. S. (2025). Cybersecurity Threats and Mitigation Strategies in AI Applications. <https://doi.org/10.53735/cisse.v12i1.199>

- Chan, A., Ezell, C., Kaufmann, M., Wei, K., Hammond, L., Bradley, H., Bluemke, E., Rajkumar, N., Krueger, D., Kolt, N., Heim, L., and Anderljung, M. (2024). Visibility into AI Agents. In Proceedings of the 2024 ACM Conference on Fairness, Accountability, and Transparency (pp. xx–xx). ACM. <https://doi.org/10.1145/3630106.3658948>
- Chen, A., Wu, Y., Zhang, J., Xiao, J., Yang, S., Huang, J.-T., Wang, K., Wang, W., and Wang, S. (2025a). JARVIS or Ultron? A Survey on the Safety and Security Threats of Computer-Using Agents (arXiv:2505.10924). arXiv.
- Chen, S., Piet, J., Sitawarin, C., and Wagner, D. (2024). StruQ: Defending Against Prompt Injection with Structured Queries. arXiv.
- Chen, Y., Li, H., Zheng, Z., Wu, D., Song, Y., and Hooi, B. (2025b). Defense Against Prompt Injection Attack by Leveraging Attack Techniques (18331–18347). <https://doi.org/10.18653/v1/2025.acl-long.897>
- Chennabasappa, S., Nikolaidis, C., Song, D., Molnar, D., Ding, S., Wan, S., and Saxe, J. (2025). LlamaFirewall: An Open Source Guardrail System for Building Secure AI Agents (arXiv:2505.03574). arXiv.
- Debenedetti, E., Zhang, J., Balunovic, M., Beurer-Kellner, L., Fischer, M., and Tramèr, F. (2024). AgentDojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM agents.
- Deng, Z., Guo, Y., Han, C., Ma, W., Xiong, J., Wen, S., and Xiang, Y. (2025). AI Agents Under Threat: A Survey of Key Security Challenges and Future Pathways. ACM Computing Surveys. <https://doi.org/10.1145/3716628>
- Domkundwar, I., NS, M., Kochhar, R., and Bhola, I. (2024). Safeguarding AI Agents: Developing and Analyzing Safety Architectures.
- Guo, Q., Tang, J., and Huang, X. (2025). Attacking LLMs and AI Agents: Advertisement Embedding Attacks Against Large Language Models (arXiv:2508.17674). <https://doi.org/10.1109/FMLDS67896.2025.00111>
- He, Y., Wang, E., Rong, Y., Cheng, Z., Chen, H., and University of California, Davis. (2025). Security of AI Agents. In 2025 IEEE/ACM International Workshop on Responsible AI Engineering (RAIE). <https://doi.org/10.1109/RAIE66699.2025.00013>
- Huang, C., Zhang, Z., Mao, B., and Yao, X. (2023). An Overview of Artificial Intelligence Ethics. IEEE Transactions on Artificial Intelligence, 4(4), 799–819. <https://doi.org/10.1109/TAI.2022.3194503>
- Igenewari, L. S., and Okoh, O. E. (2025). Adversarial Attacks and Defenses in AI Systems: Challenges, Strategies, and Future Directions. International Journal of Research and Innovation in Applied Science, 10(6). <https://doi.org/10.51584/IJRIAS.2025.10060075>
- Kwesi, J., Cao, J., Manchanda, R., and Emami-Naeini, P. (2025). Exploring user Security and Privacy Attitudes and Concerns Toward the Use of General-Purpose LLM Chatbots for Mental Health. In Proceedings of the 34th USENIX Security Symposium.
- Mauri, L., and Damiani, E. (2022). Modeling Threats to AI-ML Systems using STRIDE. Sensors, 22(17), 6662. <https://doi.org/10.3390/s22176662>
- Mayoral-Vilches, V., Rynning, P. M., and Pornillos, A. (2025). Cybersecurity AI: Hacking the AI Hackers Via Prompt Injection (arXiv:2508.21669). arXiv.
- Motwani, S. R., Baranchuk, M., Strohmeier, M., Bolina, V., Torr, P. H. S., Hammond, L., and Schroeder de Witt, C. (2024). Secret Collusion Among AI Agents: Multi-Agent Deception Via Steganography. Advances in Neural Information Processing Systems. <https://doi.org/10.52202/079017-2336>
- Mudryi, M., Chaklosh, M., and Wójcik, G. M. (2025). The Hidden Dangers of Browsing AI Agents (arXiv:2505.13076). <https://doi.org/10.2139/ssrn.5290351>
- Narajala, V. S., and Narayan, O. (2025). Securing Agentic AI: A Comprehensive Threat Model and Mitigation Framework for Generative AI Agents (pp. 1–6). <https://doi.org/10.1109/ACAI68217.2025.11406310>
- Perez, F., and Ribeiro, I. (2022). Ignore Previous Prompt: Attack Techniques for Language Models (arXiv:2211.09527). arXiv.
- Rossi, S., Michel, A. M., Mukkamala, R. R., and Thatcher, J. B. (2024). An Early Categorization of Prompt Injection Attacks on Large Language Models (arXiv:2402.00898). arXiv.
- Schroeder de Witt, C. (2025). Open Challenges in Multi-Agent Security: Towards Secure Systems of Interacting AI Agents. arXiv. <https://doi.org/10.48550/arXiv.2505.02077>
- Security and Privacy for Artificial Intelligence: Opportunities and challenges. (2020).
- Shahriar, A., Rahman, M. N., Ahmed, S., Sadeque, F., and Parvez, M. R. (2025). A Survey on Agentic Security: Applications, Threats and Defenses (arXiv:2510.06445). Arxiv.
- Sharma, G., Kulkarni, V., King, M., and Huang, K. (2025). Towards Unifying Quantitative Security Benchmarking for Multi-Agent Systems (arXiv:2507.21146). arXiv.
- Su, H., Luo, J., Liu, C., Yang, X., Zhang, Y., Dong, Y., and Zhu, J. (2025). A Survey on Autonomy-Induced Security Risks in Large Model-Based Agents. IEEE Transactions on Pattern Analysis and Machine Intelligence. <https://doi.org/10.1109/TPAMI.2026.3688650>
- Tete, S. B. (2024). Threat Modelling and Risk Analysis for Large Language Model (LLM)-Powered Applications (arXiv:2406.11007). arXiv.
- Uuk, R., Brouwer, A., Schreier, T., Dreksler, N., Pulignano, V., and Bommasani, R. (2024). Effective Mitigations for Systemic Risks from General-Purpose AI (arXiv:2412.02145). <https://doi.org/10.2139/ssrn.5021463>
- Wang, Y., Pan, Y., Guo, S., and Su, Z. (2025a). Security of Internet of Agents: Attacks and Countermeasures. IEEE Open Journal of the Computer Society. <https://doi.org/10.1109/OJCS.2025.3589638>

- Wang, Z., Nagaraja, N., Zhang, L., Bahsi, H., Patil, P., and Liu, P. (2025b). To Protect the LLM Agent Against the Prompt Injection Attack with Polymorphic Prompt. <https://doi.org/10.1109/DSN-S65789.2025.00037>
- Yu, J., Wu, Y., Shu, D., Jin, M., Yang, S., and Xing, X. (2024). Assessing Prompt Injection Risks in 200+ Custom GPTs (arXiv:2311.11538). arXiv.
- Zhang, B., Tan, Y., Shen, Y., Salem, A., Backes, M., Zannettou, S., and Zhang, Y. (2024). Breaking Agents: Compromising Autonomous LLM Agents Through Malfunction Amplification (arXiv:2407.20859). <https://doi.org/10.18653/v1/2025.emnlp-main.1771>
- Zou, A., Lin, M., Jones, E., Nowak, M., Dziemian, M., Winter, N., and Fredrikson, M. (2025). Security Challenges in AI Agent Deployment: Insights from a Large-Scale Public Competition (arXiv:2507.20526). arXiv.